

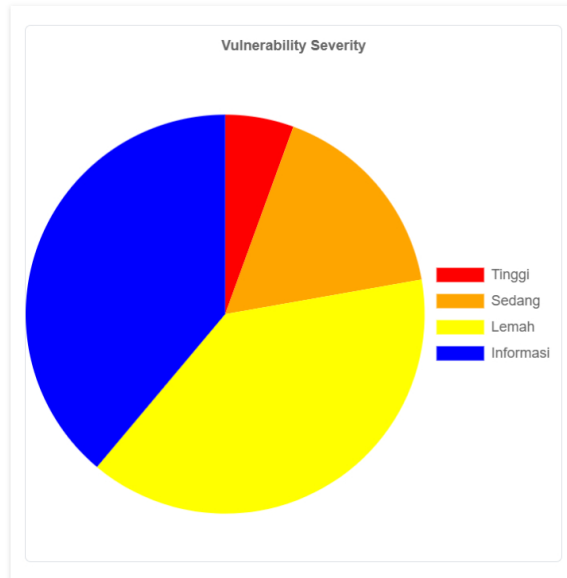
Generated on Rab, 22 Jul 2026 07:40:03

ZAP Version: 2.17.0

ZAP by [Checkmarx](#)

Most Severe Alert

High

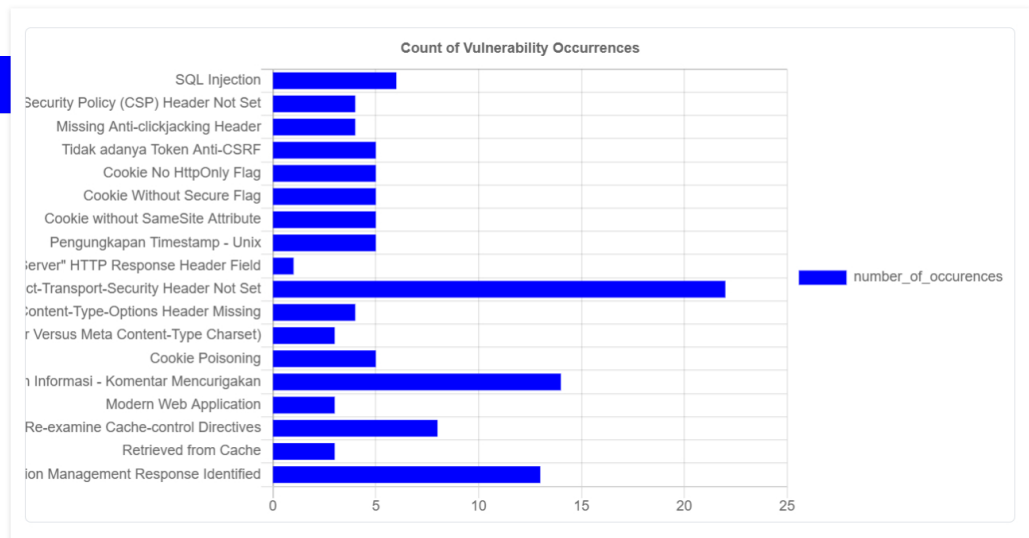


Report Description

- Laporan ini ditulis dan disusun oleh :
- Habib Muzakki (Habib)
- Alumni Kelas 12 Agama (jurusan Agama)
- Alumni MAN 2 KOTA SERANG
- Mahasiswa D4 Vokasi Teknik Informatika (Harkat Negeri Tegal)
- Si pemula Cyber Security dan Bug Hunter (Bug Bounty)

Most Common Bug

Strict-Transport-Security Header Not Set (22)



Insights

Level	Alasan	Site	Deskripsi	Statistic
Lemah	Peringatan		ZAP errors logged - see the zap.log file for details	7
Lemah	Peringatan		ZAP warnings logged - see the zap.log file for details	19
Lemah	Exceeded High	https://google-gruyere.appspot.com	Percentage of slow responses	96 %
Info	Informasi	http://clients2.google.com	Percentage of responses with status code 2xx	100 %
Info	Informasi	http://clients2.google.com	Percentage of endpoints with content type application/json	100 %
Info	Informasi	http://clients2.google.com	Percentage of endpoints with method GET	100 %
Info	Informasi	http://clients2.google.com	Count of total endpoints	1
Info	Informasi	http://clients2.google.com	Percentage of slow responses	100 %
Info	Informasi	https://accounts.google.com	Percentage of responses with status code 2xx	100 %
Info	Informasi	https://accounts.google.com	Percentage of endpoints with content type application/binary	100 %

Info	Informasi	https://accounts.google.com	Percentage of endpoints with method POST	100 %
Info	Informasi	https://accounts.google.com	Count of total endpoints	1
Info	Informasi	https://accounts.google.com	Percentage of slow responses	50 %
Info	Informasi	https://android.clients.google.com	Percentage of responses with status code 2xx	40 %
Info	Informasi	https://android.clients.google.com	Percentage of responses with status code 3xx	60 %
Info	Informasi	https://android.clients.google.com	Percentage of endpoints with content type application/x-protobuf	33 %
Info	Informasi	https://android.clients.google.com	Percentage of endpoints with content type text/plain	66 %
Info	Informasi	https://android.clients.google.com	Percentage of endpoints with method POST	100 %
Info	Informasi	https://android.clients.google.com	Count of total endpoints	3
Info	Informasi	https://android.clients.google.com	Percentage of slow responses	100 %
Info	Informasi	https://beacons.gcp.gvt2.com	Percentage of responses with status code 2xx	100 %
Info	Informasi	https://beacons.gcp.gvt2.com	Percentage of endpoints with content type application/javascript	100 %
Info	Informasi	https://beacons.gcp.gvt2.com	Percentage of endpoints with method POST	100 %
Info	Informasi	https://beacons.gcp.gvt2.com	Count of total endpoints	2
Info	Informasi	https://beacons.gcp.gvt2.com	Percentage of slow responses	100 %
Info	Informasi	https://chromewebstore.googleapis.com	Percentage of responses with status code 2xx	100 %
Info	Informasi	https://chromewebstore.googleapis.com	Percentage of endpoints with content type application/x-protobuf	100 %
Info	Informasi	https://chromewebstore.googleapis.com	Percentage of endpoints with method POST	100 %
Info	Informasi	https://chromewebstore.googleapis.com	Count of total endpoints	1
Info	Informasi	https://chromewebstore.googleapis.com	Percentage of slow responses	100 %
Info	Informasi	https://clientservices.googleapis.com	Percentage of responses with status code 2xx	100 %
Info	Informasi	https://clientservices.googleapis.com	Percentage of endpoints with content type text/plain	100 %
Info	Informasi	https://clientservices.googleapis.com	Percentage of endpoints with method POST	100 %
Info	Informasi	https://clientservices.googleapis.com	Count of total endpoints	1
Info	Informasi	https://clientservices.googleapis.com	Percentage of slow responses	100 %
Info	Informasi	https://content-autofill.googleapis.com	Percentage of responses with status code 2xx	100 %
Info	Informasi	https://content-autofill.googleapis.com	Percentage of endpoints with content type text/plain	100 %
Info	Informasi	https://content-autofill.googleapis.com	Percentage of endpoints with method GET	100 %
Info	Informasi	https://content-autofill.googleapis.com	Count of total endpoints	4
Info	Informasi	https://content-autofill.googleapis.com	Percentage of slow responses	100 %
Info	Informasi	https://google-gruyere.appspot.com	Percentage of responses with status code 2xx	81 %
Info	Informasi	https://google-gruyere.appspot.com	Percentage of responses with status code 3xx	7 %
Info	Exceeded Low	https://google-gruyere.appspot.com	Percentage of responses with status code 4xx	10 %
Info	Informasi	https://google-gruyere.appspot.com	Percentage of endpoints with content type application/javascript	5 %
Info	Informasi	https://google-gruyere.appspot.com	Percentage of endpoints with content type application/zip	1 %
Info	Informasi	https://google-gruyere.appspot.com	Percentage of endpoints with content type image/gif	1 %
Info	Informasi	https://google-gruyere.appspot.com	Percentage of endpoints with content type image/png	7 %
Info	Informasi	https://google-gruyere.appspot.com	Percentage of endpoints with content type image/vnd.microsoft.icon	1 %
Info	Informasi	https://google-gruyere.appspot.com	Percentage of endpoints with content type text/css	1 %
Info	Informasi	https://google-gruyere.appspot.com	Percentage of endpoints with content type text/html	77 %
Info	Informasi	https://google-gruyere.appspot.com	Percentage of endpoints with content type text/plain	7 %
Info	Informasi	https://google-gruyere.appspot.com	Percentage of endpoints with method GET	97 %

Info	Informasi	https://google-gruyere.appspot.com	Percentage of endpoints with method POST	2 %
Info	Informasi	https://google-gruyere.appspot.com	Count of total endpoints	253
Info	Informasi	https://optimizationguide-pa.googleapis.com	Percentage of responses with status code 2xx	100 %
Info	Informasi	https://optimizationguide-pa.googleapis.com	Percentage of endpoints with content type application/x-protobuf	50 %
Info	Informasi	https://optimizationguide-pa.googleapis.com	Percentage of endpoints with content type text/html	50 %
Info	Informasi	https://optimizationguide-pa.googleapis.com	Percentage of endpoints with method GET	50 %
Info	Informasi	https://optimizationguide-pa.googleapis.com	Percentage of endpoints with method POST	50 %
Info	Informasi	https://optimizationguide-pa.googleapis.com	Count of total endpoints	2
Info	Informasi	https://optimizationguide-pa.googleapis.com	Percentage of slow responses	100 %
Info	Informasi	https://update.googleapis.com	Percentage of responses with status code 2xx	100 %
Info	Informasi	https://update.googleapis.com	Percentage of endpoints with content type application/json	100 %
Info	Informasi	https://update.googleapis.com	Percentage of endpoints with method POST	100 %
Info	Informasi	https://update.googleapis.com	Count of total endpoints	5
Info	Informasi	https://update.googleapis.com	Percentage of slow responses	100 %
Info	Informasi	https://www.google.com	Percentage of responses with status code 2xx	100 %
Info	Informasi	https://www.google.com	Percentage of endpoints with content type application/x-protobuf	100 %
Info	Informasi	https://www.google.com	Percentage of endpoints with method GET	100 %
Info	Informasi	https://www.google.com	Count of total endpoints	1
Info	Informasi	https://www.google.com	Percentage of slow responses	100 %
Info	Informasi	https://www.googleapis.com	Percentage of responses with status code 2xx	100 %
Info	Informasi	https://www.googleapis.com	Percentage of endpoints with content type application/json	100 %
Info	Informasi	https://www.googleapis.com	Percentage of endpoints with method POST	100 %
Info	Informasi	https://www.googleapis.com	Count of total endpoints	1
Info	Informasi	https://www.googleapis.com	Percentage of slow responses	100 %

Vulnerability Impact

#	Name	Impact
SQL Injection [1]	SQL injection may be possible.	
Content Security Policy (CSP) Header Not Set [1] [2] [3] [4] [5] [6] [7]	Content Security Policy (CSP) is an added layer of security that helps to detect and mitigate certain types of attacks, including Cross Site Scripting (XSS) and data injection attacks. These attacks are used for everything from data theft to site defacement or distribution of malware. CSP provides a set of standard HTTP headers that allow website owners to declare approved sources of content that browsers should be allowed to load on that page — covered types are JavaScript, CSS, HTML frames, fonts, images and embeddable objects such as Java applets. ActiveX. audio	

	and video files.	
Missing Anti-clickjacking Header [1]	The response does not protect against 'ClickJacking' attacks. It should include either Content-Security-Policy with 'frame-ancestors' directive or X-Frame-Options.	
Tidak adanya Token Anti-CSRF [1] [2]	Tidak ada bukti Anti-CSRF yang ditemukan dalam formulir pengiriman HTML.	
Cookie No HttpOnly Flag [1]	A cookie has been set without the HttpOnly flag, which means that the cookie can be accessed by JavaScript. If a malicious script can be run on this page then the cookie will be accessible and can be transmitted to another site. If this is a session cookie then session hijacking may be possible.	
Cookie Without Secure Flag [1]	A cookie has been set without the secure flag, which means that the cookie can be accessed via unencrypted connections.	
Cookie without SameSite Attribute [1]	A cookie has been set without the SameSite attribute, which means that the cookie can be sent as a result of a 'cross-site' request. The SameSite attribute is an effective counter measure to cross-site request forgery, cross-site script inclusion, and timing attacks.	
Pengungkapan Timestamp - Unix [1]	A timestamp was disclosed by the application/web server. - Unix	
Server Leaks Version Information via "Server" HTTP Response Header Field [1] [2] [3]	The web/application server is leaking version information via the "Server" HTTP response header. Access to such information may facilitate attackers identifying other vulnerabilities your web/application server is subject to.	
Strict-Transport-Security Header Not Set [1] [2] [3] [4] [5]	HTTP Strict Transport Security (HSTS) is a web security policy mechanism whereby a web server declares that complying user agents (such as a web browser) are to interact with it using only secure HTTPS connections (i.e. HTTP layered over TLS/SSL). HSTS is an IETF standards track protocol and is specified in	

	RFC 6797.	
X-Content-Type-Options Header Missing [1] [2]	The Anti-MIME-Sniffing header X-Content-Type-Options was not set to 'nosniff'. This allows older versions of Internet Explorer and Chrome to perform MIME-sniffing on the response body, potentially causing the response body to be interpreted and displayed as a content type other than the declared content type. Current (early 2014) and legacy versions of Firefox will use the declared content type (if one is set), rather than performing MIME-sniffing.	
Charset Mismatch (Header Versus Meta Content-Type Charset) [1]	This check identifies responses where the HTTP Content-Type header declares a charset different from the charset defined by the body of the HTML or XML. When there's a charset mismatch between the HTTP header and content body Web browsers can be forced into an undesirable content-sniffing mode to determine the content's correct character set.	
Cookie Poisoning [1] [2]	This check looks at user-supplied input in query string parameters and POST data to identify where cookie parameters might be controlled. This is called a cookie poisoning attack, and becomes exploitable when an attacker can manipulate the cookie in various ways. In some cases this will not be exploitable, however, allowing URL parameters to set cookie values is generally considered a bug.	
Keterbukaan Informasi - Komentar Mencurigakan	The response appears to contain suspicious comments which may help an attacker.	
Modern Web Application	The application appears to be a modern web application. If you need to explore it automatically then the Ajax Spider may well be more effective than the standard one.	
Re-examine Cache-control Directives [1] [2] [3]	The cache-control header has not been set properly or is missing, allowing the browser and proxies to cache content. For static assets like css, js, or image files this might be intended,	

	however, the resources should be reviewed to ensure that no sensitive content will be cached.	
Retrieved from Cache [1] [2] [3]	The content was retrieved from a shared cache. If the response data is sensitive, personal or user-specific, this may result in sensitive information being leaked. In some cases, this may even result in a user gaining complete control of the session of another user, depending on the configuration of the caching components in use in their environment. This is primarily an issue where caching servers such as "proxy" caches are configured on the local network. This configuration is typically found in corporate or educational environments, for instance.	
Session Management Response Identified [1]	The given response has been identified as containing a session management token. The 'Other Info' field contains a set of header tokens that can be used in the Header Based Session Management Method. If the request is in a context which has a Session Management Method set to "Auto-Detect" then this rule will change the session management to use the tokens identified.	